

广东工业大学2025实习实训

信息安全-网络渗透实战

2025年6月

一、实训方案设计

技术方向	实训周期	计划实训时间	实训地点
信息安全网络渗透实战 基础	10天	7月7日-7月18日	线上

二、实训实施方案设计

2.1实训目标

高级 SQL 注入攻防

- 内容：
 - 二次注入原理与实战（结合用户输入与数据库交互场景）
 - JSON 注入、XML 注入等非结构化数据攻击
 - 注入漏洞与文件操作结合（如 LOAD DATA INFILE 写入 Webshell）
 - 防御方案：预编译 SQL、AST 语法树过滤、动态脱敏
- 实验：在 DVWA 高难度模式下实现盲注自动化脚本，结合文件写入获取服务器权限

反序列化漏洞高级利用

- 内容：
 - PHP 反序列化链构造（基于 POP 链原理，如 Guzzle、Doctrine 框架漏洞）
 - Java 反序列化漏洞（Commons Collections 7 链、Spring 框架漏洞）
 - 反序列化与命令执行、文件上传的漏洞链组合
 - 防御方案：类白名单限制、序列化数据签名校验
- 实验：复现 Log4j2 反序列化漏洞，结合 JNDI 注入实现远程命令执行

SSRF 漏洞深度挖掘与绕过

- 内容：
 - SSRF 对 Redis 未授权访问的利用（结合 SSRF 实现 Redis 写 SSH 密钥、反弹 Shell）
 - 内网服务探测（通过 SSRF 扫描内网 Redis、Memcached、MongoDB 服务）
 - 协议绕过技巧（file://、gopher://、dict:// 协议组合攻击）
 - 防御方案：URL 白名单、请求来源限制、内网服务隔离
- 实验：在靶机环境中通过 SSRF+Redis 未授权访问，实现服务器权限获取

系统级漏洞与权限提升

- 内容：
 - 管道符绕过（如\${IFS}替代空格、Base64 编码命令执行）
 - 环境变量利用（PATH 变量劫持、LD_PRELOAD 注入）
 - 命令执行与文件上传结合（如上传 shell 脚本配合定时任务）
 - 实验：在受限环境中（如仅允许 ping 命令）通过环境变量劫持执行任意命令

内存漏洞基础与实战

- 内容：
 - 格式化字符串漏洞（利用 %n、%s 实现内存读写）
 - 栈溢出基础（缓冲区溢出原理、EIP 覆盖）
 - 堆溢出门（UAF 漏洞原理与简单利用）
 - 防御方案：ASLR、Stack Canary、SafeSEH 等保护机制
 - 实验：在 Linux 环境中复现栈溢出漏洞，通过覆盖返回地址执行 shellcode

权限提升实战

● 内容:

- Windows 提权 (MS17-010、PrintSpoofer、令牌窃取)
- Linux 提权 (SUID 滥用、内核漏洞如脏牛)
- 域环境提权 (Kerberos 黄金票据、白银票据)
- 实验: 在 Windows 10 靶机中通过 PrintSpoofer 漏洞实现从普通用户到管理员提权

文件上传安全架构与风险管理

- 了解文件上传漏洞的类型、成因及其对系统安全的潜在威胁。
- 了解文件上传的整个流程, 包括客户端提交、服务器端接收和文件存储。
- 了解常见的文件上传验证机制, 如文件类型、大小和扩展名的检查。
- 了解绕过文件上传验证的技巧和相关工具。
- 了解服务器端的安全配置, 如设置正确的文件权限和使用安全的中间件。
- 了解客户端防御措施, 包括JavaScript验证和安全的表单设计。
- 熟练进行文件类型检测和处理, 防止恶意文件上传。
- 熟练使用文件上传安全最佳实践, 包括使用白名单、随机文件名和安全存储。
- 掌握通过实战演练加深对文件上传漏洞利用和防御的理解。
- 掌握安全审计和持续监控的设置和维护。

APP渗透

- 安卓基础及四大件
- apk目录结构和app存储位置
- adb的基础演示
- appinfoscanner的使用
- MobSF扫描四大组件
- app的反编译工具
- app脱壳
- 实验: 在模拟器上解析、脱壳、反编译app。实现从脱壳到捉包到挖掘漏洞

应急响应流程

- 应急响应流程
- 手工木马查杀
- 病毒文件分析
- linux入侵排查思路
- Webshell查杀及360星图分析web日志
- Linux下使用rootkit隐藏进程
- clamAV安装及使用

内网渗透基础

- 了解内网渗透入门概念，包括内网渗透的目的、流程和风险。
- 了解基础网络知识回顾，包括TCP/IP模型、网络协议和常见的网络设备。
- 了解内网架构与关键组件，包括域控制器、文件服务器、数据库服务器等。
- 了解基本信息搜集技术，包括使用Nmap、Wireshark等工具进行信息搜集。
- 了解常见内网服务与漏洞，包括SMB、RDP、LDAP等服务及其潜在的安全问题。
- 了解简单权限提升方法，包括利用系统漏洞和配置错误进行权限提升。
- 了解初级横向移动技术，包括使用PsExec、WMIC等工具进行内网横向移动。
- 了解基础网络嗅探与监控，包括使用Wireshark、tcpdump等工具进行网络流量分析。
- 了解简易后门技术概述，包括创建和使用简单的后门程序。
- 了解基本安全防护措施，包括使用防火墙、入侵检测系统等进行内网安全防护。

渗透基础能力综合测试

- 网络扫描与信息搜集：测试使用各种工具和技术进行目标网络的扫描和信息搜集的能力。
- 漏洞识别与利用：测试识别目标系统中的漏洞并利用这些漏洞进行攻击的能力。
- 权限提升：测试在获得初始访问权限后，提升权限至系统管理员级别的能力。
- 横向移动：测试在内部网络中移动，访问其他系统和资源的能力。
- 持久化控制：测试在目标系统中建立持久化后门，以便长期控制的能力。
- 数据渗出：测试从目标网络中提取敏感数据并将其传输到外部系统的能力。
- 防御绕过：测试绕过常见的安全防御措施，如防火墙、入侵检测系统等的能力。
- 报告编写：测试编写详细的渗透测试报告，包括发现的问题、利用过程和安全建议的能力。

2.2课程特色亮点

信息安全网络渗透实战基础课程的特色亮点主要体现在以下几个方面：

项目化实战教学：通过一系列精心设计的实战项目，将理论知识与实际操作紧密结合。学员将在模拟的真实网络环境中，亲身体验从信息收集到漏洞利用的全过程，通过解决实际问题来深化理解。每个项目都旨在模拟真实世界中的挑战，让学员在实践中学习，通过动手操作来掌握渗透测试的技能。这种教学方法不仅提高了学员的实战能力，还培养了他们的问题解决能力和团队协作精神，为成为一名合格的网络安全专家打下坚实的基础。

融合前沿技术：紧跟网络安全领域的最新发展，融合了前沿技术，确保学员能够掌握最先进的渗透测试工具和方法。我们不仅涵盖了传统的渗透测试技术，还引入了最新的攻击手段和防御策略，如人工智能在安全分析中的应用、云安全挑战与解决方案、以及物联网设备的安全漏洞分析等。通过这些前沿技术的学习，学员将能够洞察未来网络安全的趋势，提前做好准备，应对不断变化的网络威胁。我们的目标是培养学员成为能够适应未来网络安全挑战的专业人才，为保护数字世界的安全贡献力量。

跨学科融合：培养学员的综合能力，使其能够在复杂的网络安全环境中游刃有余。我们不仅教授技术层面的渗透测试技能，还融入了法律、伦理、心理学和管理学等多学科知识，帮助学员建立起全面的视角。通过学习国家信息安全法律法规，学员能够理解在渗透测试中的法律边界和责任；通过伦理学的探讨，学员将认识到在技术操作中的道德准则；而心理学和管理学的知识则有助于学员更好地理解攻击者的动机和组织内部的安全管理。这种跨学科的融合，使得学员不仅能够成为技术精湛的渗透测试专家，还能够成为具有战略眼光和领导力的网络安全领导者。

强调团队协作：本课程高度重视团队协作精神的培养，深知在网络安全领域，单打独斗远不如团队协作来得有效。我们通过分组项目和模拟实战，鼓励学员在解决复杂问题时相互协作、共同进步。在课程中，学员将学习如何有效地沟通技术细节、如何分配任务以最大化团队效率，以及如何在面对挑战时共同制定策略。我们相信，通过团队协作的实践，学员不仅能够提升个人的技术能力，还能够学会如何在多元化的团队中发挥自己的作用，共同构建一个更加安全的网络环境。这种团队协作的经验，对于学员未来无论是作为安全分析师、渗透测试专家还是网络安全管理者，都是宝贵的财富。

注重实践成果：确保学员在学习过程中不仅掌握理论知识，更能通过实际操作验证和巩固所学技能。每个模块结束后，学员都会参与实战演练和项目展示，通过解决真实世界中的安全问题来检验自己的学习成果。我们设置了多层次的评估体系，包括项目报告、实战演练成绩和团队合作表现等，全面评估学员的综合能力。通过这些实践活动，学员将积累丰富的实战经验，形成一套完整的技能体系，并能够在未来的职业生涯中自信地应对各种网络安全挑战。最终，学员不仅能够展示自己的实践成果，还能通过这些成果获得行业认可，为未来的职业发展打下坚实的基础。



[All](#) [Web](#) [Pwn](#) [Re](#) [Crypto](#) [Misc](#)

类型选择:

-所有标签-

[查看](#)

W

【基础】信息收集1

★ 100

已解决: 5

ID: 108

W

【基础】信息收集2

★ 100

已解决: 4

ID: 109

W

【基础】SQL注入1

★ 100

已解决: 5

ID: 110

W

【基础】SQL注入2

★ 100

已解决: 2

ID: 111

W

【基础】任意文件读取漏洞1

★ 100

已解决: 1

ID: 112

W

【基础】任意文件读取漏洞2

★ 100

已解决: 1

ID: 113

W

【基础】任意文件读取漏洞3

★ 100

已解决: 1

ID: 114

W

【基础】命令执行漏洞

★ 100

已解决: 0

ID: 115

W

【基础】XSS漏洞

★ 100

已解决: 1

ID: 116

W

【基础】文件上传漏洞

★ 100

已解决: 1

ID: 117

W

【基础】反序列化漏洞

★ 100

已解决: 0

ID: 118

R

【基础】APK逆向之脱壳

★ 200

已解决: 0

ID: 119

R

【基础】逆向工程基础

★ 200

已解决: 0

ID: 120

R

【基础】静态分析01

★ 0

已解决: 0

ID: 121

R

【基础】静态分析02

★ 0

已解决: 0

ID: 122

R

【基础】动态分析与调试01

★ 0

已解决: 0

ID: 123

R

【基础】动态分析与调试

★ 0

已解决: 0

ID: 124

R

【基础】算法识别01

★ 200

已解决: 0

ID: 125

R

【基础】算法识别02

★ 0

已解决: 0

ID: 126

R

【基础】算法识别03

★ 200

已解决: 0

ID: 127

R

【基础】高级语言逆向-rust

★ 0

已解决: 0

ID: 128

R

【基础】高级语言逆向-go

★ 0

已解决: 0

ID: 129

R

【基础】高级语言逆向-csharp

★ 0

已解决: 0

ID: 130

R

【基础】高级语言逆向-python

★ 0

已解决: 0

ID: 131

R

【基础】高级语言逆向-mfc

★ 0

已解决: 0

ID: 132

R

【基础】现代逆向工程

★ 0

已解决: 0

ID: 133

P

【基础】返回导向编程

★ 200

已解决: 0

ID: 134

P

【基础】格式化字符串漏洞

★ 200

已解决: 0

ID: 135

P

【基础】堆利用

★ 200

已解决: 0

ID: 137

P

【基础】栈溢出

★ 200

已解决: 2

ID: 138

W

【专题】MD5练习

★ 800

已解决: 0

ID: 141

Total: 31

95/page

1

Go to: 1

2.3项目简介

一、需求分析

随着信息技术的迅猛发展，网络安全问题日益凸显，企业和组织面临的网络威胁和攻击手段也日趋复杂和多样化。为了应对这些挑战，培养具备实战能力的网络安全专业人才成为当务之急。本课程旨在通过项目化实战教学，融合前沿技术和跨学科知识，培养学员的综合能力，提升其在实际工作中的应对能力。

二、设计规划

根据需求分析的结果，制定详细的课程设计方案。这包括确定课程模块、教学内容、实战项目和评估体系等。同时，还需要考虑课程的灵活性和可扩展性，以适应不同学员的需求。课程将涵盖从基础理论到高级技术的全面内容，确保学员能够系统地掌握渗透测试的各个环节。

三、课程内容与实施

- 高级 Web 漏洞攻防：涵盖二次注入、反序列化、SSRF 等高级漏洞的原理与利用
- 系统级漏洞与权限提升：包括命令注入、内存漏洞、系统提权等内容
- 内网渗透与实战对抗：包括内网信息搜集、横向移动、域渗透等内容
- APP渗透：包括app抓包、app反编译、app脱壳
- 应急响应：手工病毒查杀、木马样本分析、Linux、windows应急响应流程

四、设备与环境配置

根据课程设计，配置所需的硬件和软件环境。这包括高性能计算机、虚拟化平台、网络设备（如交换机、路由器）以及各种渗透测试工具和软件。确保每个学员都有独立的实验环境，以便进行实际操作和测试。

五、测试与评估

在课程实施过程中，设置多层次的评估体系，包括项目报告、实战演练成绩和团队合作表现等，全面评估学员的综合能力。通过阶段性测试和最终综合测试，确保学员掌握了课程内容并具备实际操作能力。

日程安排

时间	课程标题	课程内容
第一天	高级 SQL 注入攻防	二次注入原理与实战（结合用户输入与数据库交互场景） JSON 注入、XML 注入等非结构化数据攻击注入漏洞与文件操作结合（如 LOAD DATA INFILE 写入 Webshell） 防御方案：预编译 SQL、AST 语法树过滤、动态脱敏 实验：在 DVWA 高难度模式下实现盲注自动化脚本，结合文件写入获取服务器权限
第二天	反序列化漏洞高级利用	PHP 反序列化链构造 Java 反序列化漏洞 漏洞链组合攻击 Log4j2 漏洞复现实验
		SSRF是什么
第三天	SSRF 漏洞深度挖掘与绕过	SSRF漏洞原理 SSRF漏洞挖掘 SSRF漏洞利用（危害） 产生SSRF漏洞的函数 SSRF+redis未授权访问反弹shell SSRF漏洞的绕过方式
		SSRF漏洞的防御方法
第四天	命令执行漏洞高级利用	管道符绕过技术 环境变量利用 命令执行 文件上传
第五天	内存漏洞基础与实战	格式化字符串漏洞

		栈溢出原理与利用 堆漏洞入门 Linux 环境栈溢出
第六天	权限提升	Windows 提权（MS17-010、PrintSpoofer、令牌窃取） Linux 提权（SUID 滥用、内核漏洞如脏牛）域环境提权（Kerberos 黄金票据、白银票据） Mysql提权（UDF提权、MOD提权）
第七天	文件上传安全架构与风险管理	文件上传漏洞概述文件上传流程分析 常见上传验证机制 绕过技巧与工具 文件类型检测与处理 文件上传安全最佳实践 服务器端安全配置
		客户端防御措施 实战演练：漏洞利用与防御安全审计与持续监控
		安卓基础及四大件 apk目录结构和app存储位置 adb的基础演示
第八天	APP渗透	appinfoscanner的使用 MobSF扫描四大组件 app的反编译工具 app脱壳
		应急响应流程
第九天上午	应急响应流程	手工木马查杀 病毒文件分析 linux入侵排查思路 Webshell查杀及360星图分析web日志 Linux下使用rootkit隐藏进程 clamAV安装及使用

		内网渗透入门概念 基础网络知识回顾
第九天 下午	内网渗透基础	内网架构与关键组件 基本信息搜集技术 常见内网服务与漏洞简单权限提升方法 初级横向移动技术 基础网络嗅探与监控简易后门技术概述 基本安全防护措施
第十天	渗透基础能力综合测试	渗透基础能力综合测试